ICS 35.060
CCS L 74

中华人民共和国国家标准化指导性技术文件

GB/Z 300—2026

人工智能操作系统权限管理要求

Permission management requirements for artificial intelligence operating system

2026-09-24 发布

国家市场监督管理总局
国家标准化管理委员会 发布

目　　次

前言 ……Ⅲ
引言 ……Ⅳ
1　范围 ……1
2　规范性引用文件 ……1
3　术语和定义 ……1
4　缩略语 ……2
5　权限管理原则 ……2
6　身份管理 ……3
6.1　身份标识与鉴别 ……3
6.2　权限配置 ……3
6.3　身份数据隔离 ……3
7　权限体系 ……3
7.1　概述 ……3
7.2　权限分级 ……4
7.3　权限管理范围 ……4
7.4　授权方式 ……5
8　权限管理 ……5
8.1　权限声明 ……5
8.2　权限申请 ……6
8.3　权限授予 ……6
8.4　权限调用 ……6
8.5　权限撤销 ……8
8.6　权限配置管理 ……8
9　权限审计 ……8
9.1　审计范围 ……8
9.2　审计分析 ……8
9.3　审计处置 ……9
9.4　日志格式 ……9
9.5　日志存储 ……9
9.6　日志访问 ……9
附录A(资料性)　权限清单 ……10
附录B(资料性)　权限应用指南 ……15
参考文献 ……17

前　言

本文件为规范类指导性技术文件。

本文件按照GB/T 1.1—2020《标准化工作导则　第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由全国信息技术标准化技术委员会(SAC/TC 28)提出并归口。

本文件起草单位：中国电子技术标准化研究院、中兴通讯股份有限公司、华为终端有限公司、维沃移动通信有限公司、OPPO广东移动通信有限公司、天翼云科技有限公司、小米通讯技术有限公司、统信软件技术有限公司、中移(苏州)软件技术有限公司、荣耀终端股份有限公司、麒麟软件有限公司、北京兴云数科技术有限公司、上海文鳐信息科技有限公司、南京大学、北京健康有益科技有限公司、上海师范大学天华学院、成都理工大学、招商局重庆交通科研设计院有限公司、深城交科技集团股份有限公司、北京凝思软件股份有限公司、上海超多元子人工智能科技有限公司、元心信息科技集团有限公司、福建省标准化研究院、云从科技集团股份有限公司、中国船舶集团有限公司第七一六研究所、星尘智能(深圳)人工智能科技股份有限公司、北京东土科技股份有限公司、中移(杭州)信息技术有限公司、上海零数众合信息科技有限公司、青岛酷特智能股份有限公司、海光信息技术股份有限公司、深圳润迅人工智能科技有限公司、浦江国家实验室、中科慧拓(北京)科技有限公司、政达研学(雄安)科技有限公司、公安部第三研究所、鼎桥技术有限公司、深圳市证通电子股份有限公司、北京百度网讯科技有限公司、浙江数智交院科技股份有限公司、进迭时空(北京)科技有限公司、北京交通大学、中铁建工集团有限公司、国家工业信息安全发展研究中心、北京未来式智能科技有限公司、武汉模态跃迁科技有限公司、中国人民解放军32008部队、中科海微(北京)科技有限公司、合肥市包河区中安数字经济与公共安全研究院、海信视像科技股份有限公司、湖南麒麟信安科技股份有限公司、中电数据产业集团有限公司、浪潮计算机科技有限公司、北京国科环宇科技股份有限公司。

本文件主要起草人：王威伟、苗宗利、焦廉洁、董建、杨磊、薛志宏、史浩、孟眉、王键、姚一楠、李腾、马承青、唐杨、张希璐、高歌、李晨、商家奇、蒋彪、方强、李鹤、张胜举、李辰淑、魏刚、徐立锋、谢南淦、李根、冯京润、刘海涛、李永强、赵晓娜、刘刚、袁婷婷、仲凯韬、王楚豫、李宇欣、吕博、程晗蕾、骆中斌、许建荣、李晓宇、夏梦、陈鑫、李海晏、杨显森、陈学兵、魏遵博、梁华煜、张婷婷、兰春嘉、李海滨、展恩果、隋成龙、裴芝林、张科、苏蕾权、宋好好、黄晋飞、曾培恒、孙鑫洋、王益维、杨庄媛、汪群博、生兆亮、许智鑫、杨劲松、丁震宇、唐乐乐、公衍林、王军、纪开虎、赵敏敏、顾延甲、刘圣金、刘志立、鞠炜刚、潘宏博、冯洋、裘实、郑宁、叶青、胡芳侨、刘晶鹏、李东旭、王凯龙、杨文涵、叶培铭、杨珍、张伟琦、胡晴鹤、王和俊、林艳辉、董睿、安佳勇、赵博、周鑫羽、张宏伟、石勇、丁浩。

引　言

随着人工智能与智能体技术快速发展，人工智能操作系统作为模型调度、硬件管理与智能体运行的基础底座，其权限管理体系直接关乎系统安全、隐私保护与服务水平。操作系统向人工智能操作系统演进过程中，主体类型从单一应用扩展为应用、智能体、工具、技能等多主体的协作，主体间呈现动态协作、级联调用与自主决策等新特征。面向多主体协作的权限分级体系、授权方式及全生存周期管理机制对人工智能操作系统的权限管理提出了更高要求，特别是在智能终端和个人应用场景下，用户需要多种应用、智能体，亟需构建与之相适应的权限管理体系。

本文件在通用操作系统权限管理能力要求基础上，增加了面向智能终端和个人应用的人工智能场景下应用、智能体、工具、技能的权限管理要求，权限管理相关技术能力需要硬件等资源支撑，具体实现时可根据应用场景及设备环境进行裁剪，与 GB/Z 299 配合使用。

人工智能操作系统权限管理要求

1 范围

本文件确立了面向智能终端和个人应用场景的人工智能操作系统权限管理原则，规定了人工智能操作系统（以下简称“操作系统”）的身份管理、权限体系、权限管理、权限审计等要求。

本文件适用于面向智能终端和个人应用场景的人工智能操作系统的设计、开发、测试，也为应用、智能体等权限申请与使用提供参考和指导。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/Z 299 人工智能操作系统通用技术要求

GB/T 41867 信息技术 人工智能 术语

3 术语和定义

GB/T 41867 和 GB/Z 299 界定的以及下列术语和定义适用于本文件。

3.1

权限 permission

对一个或多个操作系统资源执行某个操作的许可。

[来源：GB/T 25062—2010，3.4，有修改]

3.2

权限管理 permission management

依据安全策略，对主体访问操作系统资源行为进行全过程管理的机制。

注：包括权限的声明、申请、授予、调用、监测、变更、撤销和审计等。

3.3

身份鉴别 identity authentication

证实一个实体所声称身份的过程。

[来源：GB/T 39786—2021，3.8]

3.4

授权 authorization

根据预先认可的安全策略，赋予主体可实施相应行为权限的过程。

[来源：GB/T 25069—2022，3.559]

3.5

安全策略 security policy

为保护操作系统安全和用户数据隐私而制定的一系列规则、规范和流程。

注：安全策略是权限管理和授权决策的依据。

3.6

上下文信息　context information

与权限决策相关的运行环境、调用场景、主体状态、客体属性、任务目的、用户授权状态、时间、地点、设备状态、网络状态、交互状态和风险状态等动态信息，用于辅助权限的动态授予与调用风险评估。

3.7

权限审计　permission audit

对主体的权限授予、变更、使用和回收过程进行记录、分析和追溯的活动。

注：权限审计用于发现未授权访问和权限滥用行为，满足合规要求。

3.8

免安装应用　installation-free application

基于操作系统或相应运行环境，用户无需下载安装即可直接运行和使用的应用程序。

注：常被称“小程序”或“快应用”。

3.9

应用聚合平台　application convergence platform

为免安装应用提供分发、搜索、运行、管理与服务入口的软件管理系统，一般是操作系统内置组件、独立的应用软件或软件模块。

3.10

用户　user

使用操作系统产品和服务的自然人或其组织。

3.11

用户数据　user data

由用户产生或为用户服务的数据。

[来源：GB/T 25069—2022，3.736]

4　缩略语

下列缩略语适用于本文件。

AI：人工智能（Artificial Intelligence）

API：应用程序接口（Application Programming Interface）

GPS：全球定位系统（Global Positioning System）

IoT：物联网（Internet of Things）

IP：网际协议（Internet Protocol）

NFC：近场通信（Near Field Communication）

UI：用户界面（User Interface）

VPN：虚拟专用网络（Virtual Private Network）

WAP：无线应用协议（Wireless Application Protocol）

WLAN：无线局域网（Wireless Local Area Network）

5　权限管理原则

人工智能操作系统权限管理原则如下：

a）　最小必要原则：系统权限设计拆分，操作方式细化，以便用户仅授予应用、智能体等主体完成其任务所必需的最小操作权限；

b） 安全隔离原则：实现不同用户、主体和安全级别数据之间的有效隔离，智能体调用各类主体时进行权限边界隔离，防止权限传递和越权访问；
c） 用户知情同意原则：涉及用户隐私、敏感权限和高危权限的授权，应将授权的目的、范围、方式和期限告知用户，并获得用户明确同意；任何主体不应强制或绕过用户授权执行操作。

6 身份管理

6.1 身份标识与鉴别

操作系统身份标识与鉴别应符合下列要求：
a） 为用户账号分配唯一标识，并在其生存周期内保持不变；
b） 基于用户标识进行用户身份鉴别和访问控制；
c） 识别部署在本系统上的应用、智能体、工具、技能等并为其分配标识，标识应与包名、命名空间、部署路径等建立映射关系，并在生存周期内唯一且不变；
d） 识别多版本应用、智能体、工具、技能并分配不同的标识；
e） 标识在生存周期结束后，不重新分配给其他用户或主体；
f） 用户级应用、智能体、工具、技能的标识仅在当前用户下有效；
g） 跨用户全局应用、智能体、技能、工具标识在所有用户下有效。

6.2 权限配置

操作系统权限配置应符合下列要求：
a） 基于用户标识对该账号访问权限进行配置；
b） 基于应用、智能体等的标识进行权限配置；
c） 权限审计日志与标识建立映射关系。

6.3 身份数据隔离

操作系统身份数据隔离应符合下列要求：
a） 不同用户间的个人数据、应用缓存、系统配置等相互隔离；
b） 不同用户对应用、智能体、云端服务等的授权状态相互隔离；
c） 不继承、复用或推断其他用户的授权配置；
d） 对各类程序可执行文件、系统资源文件及运行时产生的缓存数据进行分区存储，并配置差异化的文件系统挂载选项；
e） 支持为运行中的应用、智能体、工具等分配独立的安全沙箱环境；
f） 对应用、智能体、工具等产生的用户数据，按照当前用户标识进行隔离存储；
g） 提供统一的系统资源访问接口，避免应用、智能体、工具等直接修改或访问系统配置文件与系统分区。

7 权限体系

7.1 概述

根据权限开放可能带来的风险程度，将权限划分为普通、敏感、高危三级。根据开放的资源类型，将权限管理范围划分为系统管理、设备调用、用户数据获取、应用管理、AI 能力使用五类。操作系统常见权限清单、分级、授予方式等见附录 A。权限管理相关方的实施建议见附录 B。

注：本文件仅针对经由用户开放给应用、智能体、工具等申请的权限进行分类。

7.2 权限分级

权限分为三级，具体包括：

a） 普通权限：不涉及用户数据、系统安全，对用户权益和系统运行无实质影响，如修改音频输出设置、连接网络等；

b） 敏感权限：涉及用户数据、硬件设备的敏感功能，可能导致用户数据泄露或造成用户权益的损害，如打开摄像头、送话器、定位等；

c） 高危权限：涉及用户数据、操作系统全局控制、跨应用访问等的功能实现，可能会对用户个人信息、用户权益造成较大损害，如送话器常驻监听、输入法全局键击、录屏等。

7.3 权限管理范围

7.3.1 系统管理

对系统级服务、功能进行使用、配置，包括：

a） 基础配置：与操作系统基本交互所需要的基础资源，如运行调度、事件获取、UI修改、设置通知策略等；

b） 服务注册使用：使用系统服务或注册为系统服务，如无障碍服务、输入法、VPN、默认应用等；

c） 系统安全与策略：涉及影响系统安全状态、用户数据访问控制及系统运行策略调整，如悬浮窗管理、系统设置修改、文件访问与管理、安全策略配置等。

7.3.2 设备调用

对硬件设备所拥有资源进行访问、控制，包括：

a） 通信：调用电话、信息，连接或使用蓝牙、NFC、WLAN、移动通信网络等；

b） 音视频采集：打开摄像头、送话器等；

c） 传感器：获取设备内置加速度、陀螺仪等传感数据；

d） 设备绑定：外部设备查找、绑定、读写等；

e） 生物特征使用：使用设备指纹、人脸进行认证。

7.3.3 用户数据获取

对用户个人信息进行访问和操作，包括：

a） 通信数据：读写通话记录、通讯录、短信、彩信等；

b） 文件访问：读写用户私有目录照片、音频、视频、文档等；

c） 剪切板：读写系统剪切板；

d） 行程数据：读写日历中行程安排、提醒等信息；

e） 健康数据：读取个人心率、计步、体重、体质等运动健康服务数据；

f） 位置数据：低精度定位、高精度定位、后台定位等获得的用户位置。

7.3.4 应用管理

对操作系统上应用进行管理，包括：

a） 应用管理：应用安装与卸载、应用使用情况统计、读取已安装应用列表等；

b） 启动控制：应用自启动、创建快捷方式、关联启动等；

c） 跨应用交互：使用应用、智能体声明并对外开放的API等方式进行调用。

7.3.5 AI能力使用

应用、智能体对端侧 AI 能力的使用，包括：

a） 端侧模型部署：应用、智能体在端侧部署模型；

b） 模型推理调用：使用操作系统提供的模型服务，利用端侧模型能力完成推理过程；

c） 智能体调用：通过智能体管理服务查询安装的智能体清单，并使用智能体交互接口进行调用；

d） 工具调用：通过工具管理服务查询安装的工具清单，对应用、智能体封装并开放的工具服务接口进行调用；

e） 技能调用：通过技能管理服务查询安装的技能清单，对应用、智能体等封装并开放的技能进行调用；

f） 记忆访问：使用操作系统提供的记忆服务，读取系统智能体记忆、用户偏好记忆等数据；

g） 知识库访问：使用操作系统提供的知识库检索服务，检索系统知识库等；

h） 智能体间通信：发起或接收其他智能体的协作请求与消息。

7.4 授权方式

授权方式包括如下。

a） 安装授予：操作系统在主体安装或首次调用时自动授予权限、无需用户决策的授权方式。

b） 单次授权：由用户通过交互界面授予主体，在单次任务或单次使用中访问资源的权限，应在主体完成单次任务或退出后自动失效，主体再次使用应重新申请授权。

注 1：交互界面包括图形、语音等。

c） 限期授权：由用户通过交互界面授予主体，在使用时或预先限定的时间范围内访问资源的权限，有效期届满后权限自动失效，主体再次使用应重新申请授权。

注 2：“使用中允许”是限期授权的一种，表示在应用退出后，授权自动失效。

d） 长期授权：由用户通过交互界面授予主体，在用户主动撤销前持续有效的权限的授权方式，宜支持用户将长期授权降级为单次授权或限期授权。

e） 精准授权：由用户通过交互界面授予主体，限定数据、文件等的访问范围、精度、操作类型，仅授予完成功能所需的最小数据或操作，支持用户随时调整，并可降级至更小范围。

注 3：数据范围如访问选定的照片、选定的联系人等非全量数据，数据精度如提供低精度位置或高精度位置等，操作类型如前台使用而非后台使用等。

f） 规则授权：由用户授权系统智能体按照用户指令、预设规则或习惯，对其他应用、智能体运行中的权限申请进行授予、拒绝、撤销，以提高智能化交互体验；预设规则应由用户逐项确认并支持随时修改；仅适用于非高危权限，高危权限应由用户本人确认；系统智能体不应自我授权；当设定的规则或场景由满足变为不满足时，已授权的权限应自动回收。规则授权缺省为关闭。

注 4：规则根据网络环境（如是否连接 WLAN）、地理位置、时间段、设备运行模式（如驾驶模式、未成年人模式）、模型调用词元用量等，对不同应用、智能体的权限使用处理进行设定。

8 权限管理

8.1 权限声明

操作系统应建立权限声明机制，允许应用、智能体声明其所需权限清单，并符合下列要求：

a） 对应用、智能体权限声明给出统一格式，如权限名称、权限标签、权限组、权限类别、权限简明用途说明、触发条件或场景、前台或后台使用时机、访问范围等；

b） 权限声明格式公开发布；
c） 智能体安装、升级时，操作系统对其权限声明进行校验，如实向用户展示其所需或新增敏感权限清单及用途说明，并提示用户确认是否安装。

8.2 权限申请

操作系统应建立运行时权限动态申请机制，允许应用、智能体运行中根据任务需要申请权限声明中已列出的敏感权限，并符合下列要求：

a） 应用、智能体申请权限时，操作系统向用户展示所申请权限及简明用途说明，由用户进行确认；
b） 给出多种授予选项，如本次允许、使用中允许、本次拒绝等，单次授权不改变系统默认的授权规则；
c） 管理权限申请频次，单次运行期内，对同一权限被用户多次拒绝后重复多次申请的，支持用户选择不再提示；
d） 对于禁用的权限，发起权限申请时，给出提示并提供快捷跳转方式供用户进行权限配置；
e） 记录权限申请与处理记录，包括申请主体、时间、系统默认处理方式、用户处理方式、权限处理规则变更等供用户查阅。

8.3 权限授予

操作系统依据权限安全风险等级和权限应用特点提供不同授权方式，并符合下列要求。

a） 普通权限可采用安装授予。
b） 敏感权限：
   1） 宜采用运行时进行授予的方式；
   2） 可采用单次授权、预设时间的限期授权、精准授权等授权方式，应向用户提供明确授权选项，由用户选择；
   3） 可将单次授权或用户上次选择作为敏感权限授权页面的默认推荐选项；
   4） 对于后台运行状态下各类主体发起的敏感权限申请，操作系统应进行额外限制或增强提示，避免在用户无感知情况下授予敏感权限；
   5） 不宜采用长期授权方式；
   6） 可由用户设置规则授权策略，允许系统智能体在预设范围、期限、场景、风险等级的条件内，辅助处理其他应用、智能体对敏感权限的请求，涉及超出预设条件的敏感权限授权仍应由用户确认。
c） 高危权限：
   1） 使用的主体或组件应先通过操作系统身份校验；
   2） 不宜采用长期授权方式；
   3） 如需用户确认方式授权的高危权限，不应采用直接确认授权方式授权，避免由于误操作带来损失；
   4） 高危权限不应采用规则授权方式。
d） 对用户数据文件的选取等，操作系统宜提供精准授权方式授权用户数据、文件读写操作。
e） 多智能体协作模式下，操作系统宜支持按任务单次授予权限。

8.4 权限调用

8.4.1 权限调用监测

操作系统建立权限使用监测机制，对权限的申请、授予、调用、撤销等行为进行监测，并符合下列

要求：

a） 监测内容包括调用主体、主体身份标识、权限操作类型、操作目标资源、操作结果、操作时间等；

b） 对于超出应用、智能体声明所需之外的权限申请应给予用户提示；

c） 应对通讯录、送话器、相机、位置、剪切板等权限在用状态进行提示；

d） 应为应用、智能体的权限调用提供校验机制；

e） 监测结果应同步推送至权限管理控制台，支持可视化展示权限调用状态、异常预警信息、监测统计数据，便于用户快速掌握权限使用动态；

f） 宜具备对批量权限操作、跨域权限调用、智能体调用技能和工具、多技能编排执行等特殊场景的监测能力。

8.4.2 异常权限调用检测

操作系统建立异常权限调用检测机制，并符合下列要求。

a） 应预设异常权限使用检测规则，包括越权操作、权限滥用、敏感权限高频异常调用、非活跃时段操作等。

b） 支持自动识别批量权限变更、高频异常调用、长期未使用权限、越权访问未授权资源、智能体跨技能违规调用、模型超范围读取数据等异常行为。

c） 智能体协同监测到异常行为时，应对级联智能体的权限进行告警或提示，必要时可冻结相关权限。

d） 宜结合权限归属、资源敏感等级、操作行为特征、上下文信息等维度，构建多维度权限异常检测模型。

e） 宜基于风险影响因子（如权限的敏感程度、调用频次与基线偏差、调用时段与场景合理性、涉及数据量级、历史安全事件关联度等）建立风险分级制度，针对检测到的异常权限使用行为，自动触发分级响应机制：

1） 低风险异常：如长期未使用权限等，记录异常信息，告知用户，持续跟踪检测，并在权限调用记录中标记提示；

2） 中风险异常：如高频异常调用等，暂停权限执行并经用户手动确认，经用户确认后方可恢复；

3） 高风险异常：如访问用户未授权的资源、批量违规授权等，自动临时冻结或收回违规权限、阻断异常操作或锁定相关账号等，同步向用户、管理员推送风险提示，同时触发全局安全告警。

f） 支持动态迭代优化，结合历史权限使用数据、安全事件案例、最新威胁情报、业务场景变化等，定期更新检测阈值与判定逻辑，提升异常识别的准确率与适应性。

8.4.3 权限调用记录

操作系统对权限调用进行记录，并符合下列要求：

a） 记录内容应包括权限调用的主体身份、权限调用时间、权限名称、调用结果，宜包括用户授权凭证摘要、目标资源标识、调用链路等；

b） 应支持多维度查询与统计分析，可按调用主体、时间、权限、调用结果等维度快速检索；

c） 宜定期生成权限调用统计报告、异常行为统计报告等，为权限管理优化与安全审计提供数据支撑；

d） 应提供调用记录数据保护机制，防止数据被删除、篡改；

e） 宜与操作系统审计模块对接，实现记录数据的同步归集与统一管理。

8.5 权限撤销

操作系统权限撤销符合下列要求。

a) 应实现用户主动撤销功能，允许用户对已经授予应用、智能体的权限进行逐项撤销。

b) 应具备权限自动撤销机制，对符合预设撤销条件的权限进行自动回收，权限自动撤销的触发条件如权限有效期届满、应用或智能体在操作系统注销、应用或智能体身份失效、任务完成、安全风险等级升高、长期未使用权限、技能下架、技能禁用、技能过期等。

c) 权限撤销后，应同步回收权限主体对目标资源的相关权限，同时更新权限配置信息并清除权限缓存数据，再次使用时，重新提示用户授予。

d) 宜具备单项权限集中临时撤销能力，用户主动撤销某项权限后，所有依赖该权限的应用、智能体授权同步失效，且自动终止对该权限的使用。权限重新授予后，所有依赖该权限的应用、智能体自动获取对该权限的使用。

e) 权限自动撤销前可提示用户，包括撤销时间、撤销权限范围及撤销原因等。

8.6 权限配置管理

操作系统提供统一的权限配置管理入口，允许用户对权限进行集中查看与配置，并符合下列要求：

a) 应支持用户按敏感权限维度逐项对应用、智能体的权限配置，如拨打电话、通话记录、通讯录、短信、系统通知、位置、摄像头、送话器、运动传感器，以及已安装的应用、智能体、工具等的列表等；

b) 应支持用户按应用、智能体维度查看和修改其被授予的所有权限；

c) 对于高危权限，应提供独立配置入口，并对潜在风险进行提示；

d) 宜支持用户对应用、智能体等调用的配置，包括允许、拒绝、使用时询问等；

e) 宜支持用户集中查看操作系统上运行的智能体任务，如智能体名称、任务开始时间、占用系统资源、所需系统权限等。

9 权限审计

9.1 审计范围

操作系统应对权限全生存周期进行审计并生成审计日志，并符合下列要求：

a) 对用户创建、变更、注销、身份认证、权限绑定、角色变更、账号锁定解锁等全流程操作记录审计日志；

b) 对权限声明、申请、授予、调用、监测、变更、撤销等全生存周期操作记录审计日志；

c) 对规则授权策略的创建、修改、删除操作记录审计日志；

d) 对智能体自主决策执行的权限调用记录审计日志，包括决策依据类型、调用链路和执行结果；

e) 对应用、智能体、工具等执行的高危权限操作和用户敏感数据访问操作记录审计日志；

f) 对审计日志查询、读取、导出等操作记录审计日志；

g) 审计范围不应被用户、应用及智能体修改；

h) 对审计规则的修改应记录审计日志。

9.2 审计分析

操作系统权限审计分析能力符合下列要求：

a) 应支持按主体、客体、时间、操作类型、操作结果、风险等级等维度聚合分析；

b) 应支持按照权限管理原则对权限范围、目的、使用频次进行审计；

c） 宜支持基于历史权限使用基线实现异常行为自动评分定级、关联分析等智能研判。

9.3 审计处置

应具备审计处置机制，并符合下列要求：

a） 分级响应：区分权限使用异常的严重程度实施差异化处置，一般异常可仅发送告警通知，严重异常应自动触发权限临时冻结或收回，并向用户发出提示；

b） 处置闭环：权限审计响应处置宜包括告警、研判、处置、复核、归档等环节，确保问题处置完整可追溯；

c） 复盘改进：宜对典型权限使用异常、审计日志缺失或错误等事件复盘并形成案例，更新权限策略与审计规则，优化权限管理流程，防范同类问题复发。

9.4 日志格式

审计日志格式应符合下列要求：

a） 审计记录包括事件类型、事件发生的时间、触发事件的主体与客体的标识及名称、事件成功或失败、调用链标识、事件成功或失败的状态码及简要说明等字段；

b） 用户身份认证事件审计记录包括认证方式、终端标识、认证结果描述等字段；

c） 权限变更事件审计记录包括变更发起来源、变更前权限配置内容、变更后权限配置内容、审批人标识、审批结果等字段；

d） 网络会话事件审计记录包括网络程序名称、协议类型、源IP地址、目的IP地址、源端口、目的端口等字段；

e） 智能体审计记录包括智能体标识、智能体操作、技能调用、技能版本、调用指令、模型编号、模型操作等。

9.5 日志存储

审计日志存储应符合下列要求：

a） 审计日志存储在掉电非易失性存储介质中；

b） 未达到法规要求或预设留存期限的审计日志不因权限撤销而被覆盖或删除；

c） 具备访问控制与写入约束，如权限隔离、文件系统不可变属性、哈希链式校验等措施；

d） 存储空间达到设定容量阈值时，优先清理已超过规定留存期限的审计日志，对于尚未超过留存期限的审计日志，应进行压缩归档处理，防止审计事件意外丢弃；

e） 提供审计日志的轮转机制，支持按存储容量阈值或时间周期自动触发日志轮转；

f） 当审计日志存储空间写满且存在未到期日志时，系统触发告警通知，并视情况暂停非核心业务操作，直至管理员完成日志归档或存储空间扩容。

9.6 日志访问

审计日志访问应符合下列要求：

a） 保护审计日志不被未授权访问；

b） 保护审计日志不被非授权篡改和删除。

附 录 A
（资料性）
权限清单

表A.1列出了常见权限清单、分级、授予方式等，操作系统可根据部署与应用场景进行裁剪、扩充、合并。仅运行环境配备相应设备或系统具备相应业务数据时，操作系统需建立相应的权限体系。

表 A.1 常见权限清单、分级、授予方式

大类	权限/工具	权限分级	管理范围	授予方式	权限说明	适用场景
通讯录	读取联系人	敏感	用户数据获取	单次授权、长期授权、精准授权	—	仅限具有移动通信功能设备
	写/删除联系人	敏感	用户数据获取	单次授权、长期授权		
	查找设备上账号	敏感	用户数据获取	单次授权、长期授权	允许应用获取你手机上已添加的所有账号列表	
电话	呼叫转移	敏感	设备调用	单次授权、长期授权	允许应用查询、设置或管理设备的呼叫转移功能	仅限具有移动通信功能设备
	发起多方通话	敏感	设备调用	单次授权、长期授权	允许应用发起或管理一个多方通话	
	接听来电	敏感	设备调用	单次授权、长期授权	接听/拒绝来电	
	读取电话号码	敏感	设备调用	单次授权、长期授权	读取本机电话号码	
	获取手机识别信息	敏感	设备调用	单次授权、长期授权	读取设备ID、网络及通话状态	
	拨打电话	敏感	设备调用	单次授权、长期授权	允许应用直接拨出电话	
日历	读取日程表	敏感	用户数据获取	单次授权、长期授权	—	—
	修改/添加日程表	敏感	用户数据获取	单次授权、长期授权		
通话记录	读取通话记录	敏感	用户数据获取	单次授权、长期授权、精准授权	—	仅限具有移动通信功能设备
	写/删除通话记录	敏感	用户数据获取	单次授权、长期授权		
	重新设置外拨电话的路径	高危	用户数据获取	单次授权、不准许	查看即将拨打的电话号码，并有权将其修改为其他号码或完全中止这次通话	
信息	读取短信/彩信	敏感	用户数据获取	单次授权、长期授权、精准授权	—	仅限具有移动通信功能设备

表 A.1　常见权限清单、分级、授予方式（续）

大类	权限/工具	权限分级	管理范围	授予方式	权限说明	适用场景
信息	写/删除短信/彩信	敏感	用户数据获取	单次授权、长期授权	—	仅限具有移动通信功能设备
	接收WAP信息	敏感	用户数据获取	单次授权、长期授权		
	接收彩信	敏感	用户数据获取	单次授权、长期授权		
	接收短信	敏感	用户数据获取	单次授权、长期授权		
	发送短信	敏感	用户数据获取	单次授权、长期授权		
	发送彩信	敏感	用户数据获取	单次授权、长期授权		
闹钟	设置闹钟	普通	用户数据获取	安装授予	—	—
	锁屏时弹出全屏界面	普通	用户数据获取	安装授予		
照片/视频	读取图片或视频文件	敏感	用户数据获取	单次授权、长期授权、精准授权	—	—
音乐/音频	读取音频文件	敏感	用户数据获取	单次授权、长期授权、精准授权	—	—
	控制/修改音频设置	普通	设备调用	安装授予		
文件	访问文件	敏感	用户数据获取	单次授权、长期授权	如邮件中添加附件，需要开启该权限	—
	删除/修改文件	敏感	用户数据获取	单次授权、长期授权	—	
相机	拍照/摄像	敏感	设备调用	单次授权、长期授权	允许应用直接访问摄像头硬件，进行拍照或录像；不应在后台调用	—
应用操作	应用安装	敏感	应用管理	单次授权、长期授权	—	—
	应用卸载	敏感	应用管理	单次授权		
	应用升级	敏感	应用管理	单次授权		
	读取已安装应用列表	敏感	应用管理	单次授权、长期授权		
	应用自启动	高危	应用管理	单次授权、不准许		
传感器	识别身体活动	敏感	设备调用	单次授权、长期授权	通过设备的传感器（如加速度计、陀螺仪）识别用户当前的身体活动（如步行、骑车或驾车）	—

表 A.1　常见权限清单、分级、授予方式（续）

大类	权限/工具	权限分级	管理范围	授予方式	权限说明	适用场景
传感器	身体传感器	敏感	设备调用	单次授权、长期授权	访问设备身体传感器(如心率监测器、血氧传感器等)的权限	—
	位置	敏感	用户数据获取	单次授权、长期授权	获取设备的高精度实时位置,如GPS	
近场通信	NFC开/关	敏感	设备调用	单次授权、长期授权	—	—
	无线局域网开/关	敏感	设备调用	单次授权、长期授权	开关无线局域网	
	与附近的WLAN设备互动	敏感	设备调用	单次授权、长期授权	允许应用执行下列与附近无线局域网设备相关的操作:发现与连接、发起连接、管理热点	
	蓝牙扫描设备、被设备发现、连接已配对设备	敏感	设备调用	单次授权、长期授权	—	
	蓝牙开/关	敏感	设备调用	单次授权、长期授权		
联网	读取网络状态	普通	设备调用	安装授予	—	—
	联网	普通	设备调用	安装授予		
通知	状态栏通知或任务栏通知	普通	系统调用	长期授权、不准许	允许应用向用户推送通知消息	—
	悬浮窗通知	普通	系统调用	长期授权、不准许	允许应用向用户推送通知消息	—
	锁屏通知	普通	系统调用	长期授权、不准许		
送话器	录音	敏感	设备调用	单次授权、长期授权	允许应用访问设备的送话器,录制音频	—
	送话器常驻监听	高危	设备调用	单次授权、长期授权、不准许	允许应用监听送话器进行唤醒词监测或连续对话	
系统管理	无障碍服务	高危	系统管理	单次授权、不准许	—	—
	悬浮窗	高危	系统管理	单次授权、不准许		
文件系统	读取文件	敏感	AI能力使用	单次授权、长期授权	读、写、编辑文件、列出文件/文件夹清单、根据模式匹配查找文件,如**/*.ts,应用代码补丁	—
	写入文件	敏感	AI能力使用	单次授权、长期授权		
	编辑文件	敏感	AI能力使用	单次授权、长期授权		
	列出目录中的文件和文件夹	敏感	AI能力使用	单次授权、长期授权		
	文件查找	普通	AI能力使用	安装授予		

表 A.1　常见权限清单、分级、授予方式（续）

大类	权限/工具	权限分级	管理范围	授予方式	权限说明	适用场景
网络操作	执行网络搜索	普通	AI能力使用	安装授予	查找最新资料、抓取网页信息、监控社交媒体动态	—
	获取网页内容	普通	AI能力使用	安装授予		
	搜索社交媒体	普通	AI能力使用	安装授予		
浏览器	操作和控制浏览器会话	敏感	AI能力使用	单次授权、长期授权、不准许	自动填写表单、执行复杂的网页交互	—
	实现浏览器自动化	敏感	AI能力使用	单次授权、长期授权、不准许		
智能体管理	检查非应用内部的会话状态	敏感	AI能力使用	单次授权、长期授权、不准许	管理长对话、拆分复杂任务、协调多个AI智能体共同工作	—
	委派工作给其他智能体	敏感	AI能力使用	单次授权、长期授权、不准许		
	管理多智能体协作	敏感	AI能力使用	单次授权、长期授权、不准许		
媒体	生成图片	普通	AI能力使用	安装授予	根据描述生成插图、制作短视频、将文本转为语音输出	—
	生成视频	普通	AI能力使用	安装授予		
	文本转语音	普通	AI能力使用	安装授予		
	截屏	高危	AI能力使用	单次授权、不准许	—	
	读屏	高危	AI能力使用	单次授权、不准许		
	录屏	高危	AI能力使用	单次授权、不准许		
记忆	长期记忆搜索信息	敏感	AI能力使用	单次授权、长期授权	让AI记住用户偏好、回顾历史对话关键信息	—
	获取特定的记忆内容	敏感	AI能力使用	单次授权、长期授权	—	
	更新工作记忆	敏感	AI能力使用	单次授权、长期授权	将当前任务的进度和关键信息持久化到短期记忆中	
	写入长期记忆	敏感	AI能力使用	单次授权、长期授权	将成功的经验“晶化”为可复用的技能，存入长期记忆	
	RAG检索	敏感	AI能力使用	单次授权、长期授权	—	
	读取系统提示词模板	敏感	AI能力使用	单次授权、长期授权		

表 A.1　常见权限清单、分级、授予方式（续）

大类	权限/工具	权限分级	管理范围	授予方式	权限说明	适用场景
操作系统会话管理	列出所有会话	敏感	AI能力使用	单次授权、长期授权	—	—
	读取特定会话的历史记录	敏感	AI能力使用	单次授权、长期授权		
	向另一个会话发送消息	敏感	AI能力使用	单次授权、长期授权		
	为后台任务生成一个独立的子会话	敏感	AI能力使用	单次授权、长期授权		
	让出当前会话的控制权	敏感	AI能力使用	单次授权、长期授权		
	用于控制和管理子智能体	敏感	AI能力使用	单次授权、长期授权		
	检查当前会话的状态	敏感	AI能力使用	单次授权、长期授权		
节点控制	控制已配对的设备(如IoT设备、手机等)	敏感	AI能力使用	单次授权、长期授权	控制智能家居、与移动设备交互	—

附 录 B
（资料性）
权限应用指南

B.1 概述

本附录给出了权限管理相关方的实施建议，以促进权限管理体系的落实与应用生态互通。

本附录所述的应用、智能体、应用聚合平台，均是指部署并运行在当前操作系统上的软件，运行于云侧的软件不适用。

B.2 应用权限管理

应用（含系统预置应用、用户安装应用、免安装应用）的权限应用遵循以下原则：

a） 根据自身核心功能需求仅申请对应权限，不申请与功能无关的敏感权限、高危权限；
b） 不因部分非核心权限缺失而拒绝提供基础服务，保障用户正常使用权益；
c） 不通过隐蔽、欺诈等手段诱导用户授予权限；
d） 权限使用过程中明确说明权限用途、使用范围及时效，不静默调用敏感权限；
e） 开放API并进行工具化封装，为智能体调用提供支撑；
f） 对调用行为主体进行身份校验，拒绝非法调用、超范围调用及恶意调用；
g） 被授予高危权限的应用仅实现与其核心目标相关功能，避免高危权限被超范围滥用，如输入法应用、无障碍应用、公共安全事件预警提醒等。

B.3 智能体

智能体权限应用遵循以下原则：

a） 参照B.2进行权限申请与使用；
b） 建立用户数据授权有效期机制，明确授权默认有效期，有效期届满后，自动清除已获取的所有用户数据（含本地缓存、临时存储），若继续使用用户数据，再次向用户提交申请并获得明确授权；
c） 建立数据存储加密规范，形成端云一体的数据安全防护体系，数据传输采用端到端加密方式，防范数据传输、存储过程中的泄露风险；
d） 未经用户明示许可，不将用户个人数据（含用户画像记忆）用于超出原授权范围的用途，如AI模型训练、第三方共享等，不擅自泄露、篡改用户数据；
e） 优先通过操作系统提供的智能体管理服务、技能管理服务、工具管理服务等，查询部署在操作系统上的智能体、工具、技能，并通过其描述的接口调用规范进行调用，调用过程中携带自身身份标识；
f） 全面留存权限申请与调用日志，以及智能体、工具、技能的调用日志，确保行为可追溯；
g） 调用代码生成与执行工具的智能体在沙箱环境内结束后，即刻销毁运行空间与获得的临时授权。

B.4 应用聚合平台

应用聚合平台权限应用遵循以下原则：

a） 参考本文件建立完善的身份鉴别、权限定义、授权管理、权限审计、日志管理能力，实现对平台内

所有应用(含免安装应用)、技能的权限统一管理;

b) 对平台内所有应用运行存储空间进行隔离,默认不直接互访;

c) 平台不应将自身获得授权绕过用户授权传给平台内应用;

d) 对平台内应用、技能的权限申请、使用情况进行实时监控,发现违规申请、越权使用等行为及时拦截、告警,必要时采取限制使用、下架等处置措施;

e) 留存平台内所有应用的权限操作、身份鉴别、异常处置等日志,日志留存期限不少于6个月,满足审计与追溯需求。

B.5 应用商店

应用商店权限应用遵循以下原则:

a) 建立涵盖应用、智能体、技能的分发管理体系;

b) 开展权限审核,确认应用、智能体、工具、技能的权限声明与使用符合本文件要求;

c) 展示应用、智能体所需敏感权限清单及用途说明等,供用户审阅确认;

d) 建立监测体系,对违规申请、越权使用等行为进行告警,必要时可采取下架等处置措施。

参 考 文 献

[1] GB/Z 185.1—2026 人工智能 智能体互联 第1部分:总体架构
[2] GB/T 25062—2010 信息安全技术 鉴别与授权 基于角色的访问控制模型与管理规范
[3] GB/T 25069—2022 信息安全技术 术语
[4] GB/T 39786—2021 信息安全技术 信息系统密码应用基本要求